

22/01/22

Marking Scheme

10 Surprise Quizzes (5 marks each, best of 8 will be taken) = 40 Marks

Midterm = 25 Marks

Endterm = 25 Marks

Participation = 10 Marks

Module 1: Introduction to Cyber Security

What is Security & Safety?

Security refers to protection from attacks whereas Safety refers to actions that we take to protect ourselves.

For example, having a watchman in your building is a Security measure whereas locking your door while you leave the room is a Safety measure.

Absence of Safety doesn't cause any direct harm but it can leave you vulnerable. For example, a thief can bypass your building's security measures and get direct access to your home in case you forgot to enable the Safety measure of locking your door.

These same terms can be applied to the Cybersecurity domain as well.

Layers of Security

1. Physical
2. Personal
3. Operations
4. Communications
5. Computer
6. Network
7. Information

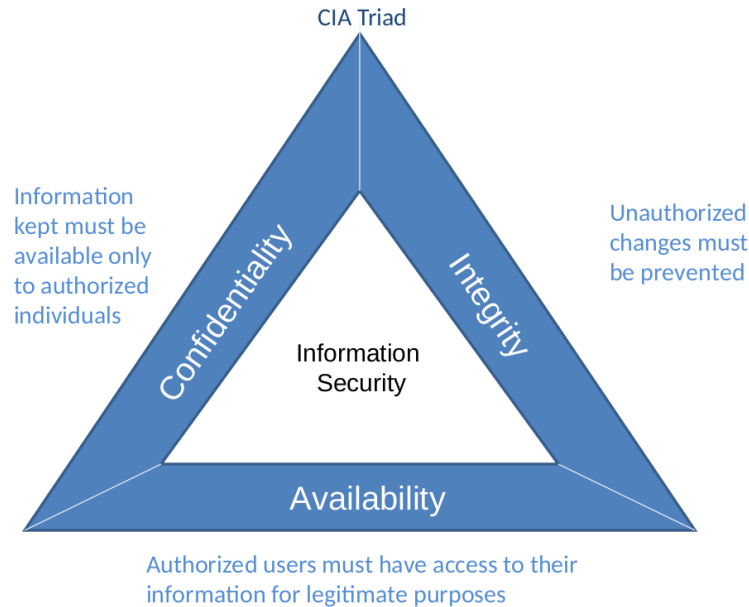
Vulnerability, Threat & Control

Vulnerability refers to a weakness in the system.
It allows a threat to cause harm.

Threat is a potential negative harmful occurrence.
Earthquake, worm, virus, hackers, etc.

Control/Safeguard is a protective measure for reducing risk of protection of an asset.

CIA Triad - Confidentiality, Integrity, Availability



Note: From "Information Security Illuminated"(p.3), by Solomon and Chapple, 2005, Sudbury, MA: Jones and Bartlett.



Confidentiality: The property that information is not accessible (made available or disclosed) to unauthorised individuals, entities or processes. It ensures that sensitive data does not land in the wrong hands.

Integrity: Data cannot be modified in an unauthorised or undetected manner. It provides assurance over accuracy and completeness over the data's entire life cycle.

Availability: Relevant information is readily accessible to those authorised to view it at all times. It ensures information is available when needed.

If you try to increase the Availability then the Confidentiality can be compromised. If you try to increase Confidentiality by putting more restrictions on access then Availability gets negatively affected.

So Cybersecurity is a balancing act of these 3 components.

The threats associated with these 3 components are,

Confidentiality => Disclosure

Integrity => Alteration

Availability => Denial (DDoS and stuff)

Threats

1. **Interception**

Gaining access to an asset like wireless network, hacked systems, etc.
Impacts confidentiality.

2. **Interruption**

Impacts availability.

3. **Modification**

Tamper with data.
Impacts integrity.

4. **Fabrication**

Spurious (wrong, invalid or fake) transactions.
Impacts integrity.

These threats emerge as part of Vulnerabilities of **Hardware, Software and/or Data**.

Modification => Changing existing data.

Fabrication => Creating new data that never existed, thereby making it fake or spurious data.

Things an Attacker Needs

1. **Method**

Skills, knowledge, tools.

2. **Opportunity**

Time and access to accomplish the attack.

3. **Motive**

A reason to want to attack.

Vulnerabilities

Logic Bomb: Employee Modification

Trojan Horse: Overtly does one thing and another covertly.

Virus: Malware which requires a carrier.

Trapdoor: Creates secret entry points for the attacker.

Developers might create these trapdoors in order to monitor the website and track performance or something of that sort. But once the app or website is in production, such trapdoors are no longer required and should be closed. And ofcourse it can happen that some of these are not

closed due to one reason or another, leaving easy openings for attackers to infiltrate into the system.

Information Leak: Makes information accessible to unauthorized people.

Worm: Malware that self-propagates.

Computer Criminals / Types of Attackers

Script Kiddies: Amateurs

Crackers/Malicious Hackers: Black Hats

Career Criminals: Botnets, Bank thefts

Terrorists: Local and Remote

Hacktivists: Politically motivated

Insiders: Employees

Phishers/Spear Phishers

...

Nowadays you have Hacker Syndicates like Anonymous which are a collection of Hacker groups.

Motives of Attackers

Financial gain: To make money

Competitive advantage: Steal information (China comes to mind)

Curiosity: To test one's skills (like some smartass students)

Political: Achieve a political goal

Cause Harm/Damage: To reputation or financial harm (not for gain, just to wreak havoc)

Vendetta/Disgruntled: Fired employees (they know your organization's insider mechanisms very well, leading them to become even more dangerous)

How to deal with Risk

Accept it: When it is cheaper to leave it unprotected.

Mitigate it: Lowering the risk to an acceptable level, e.g. laptop encryption

Transfer it: Insurance model, i.e. cyber insurance, so there will be a third-party insurance company involved that will assess your cybersecurity.

Avoid it: Sometimes it is better to not do something that creates a great risk.

Risk Mitigation

1. Prevent it by fixing vulnerabilities.

2. Deter attackers by making it harder for them to attack.

Honeypots => Create a softer target in order to learn the method of the hackers using which you can make your critical points harder to attack

3. Deflect risk by making other targets more attractive.

4. Detect it as it happens.
5. Recover from its effects.

Types of Controls

Preventive: Prevent actions.

Detective: Notice & alert.

Corrective: Correcting a damaged system.

Recovery: Restore functionality after incident.

Deterrent: Deter users from performing actions.

Compensating: Compensate for weakness in another control.

Possible Controls

Encryption: Improves Confidentiality and Integrity

Examples, VPN, SSH, Hashes, Data at Rest, Laptops.

Software: OS and Development

Hardware: Firewall, locks, IDS, 2-Factor

Policies and Procedures: Password changes

Physical: Gates, Guards, Site Planning

Security Principles

Easiest Penetration: Attackers use any means available to attack.

Adequate Protection: Protect computers/data until they lose their value.

Effectiveness: Controls must be used properly to be effective. Efficiency is key as availability of the system shouldn't be drastically compromised.

Weakest Link: The system is only as strong as its weakest link.

CIA Summary

Confidentiality: Authorised Access

Integrity: Accurate unmodified consistent data

Availability: Get access when needed

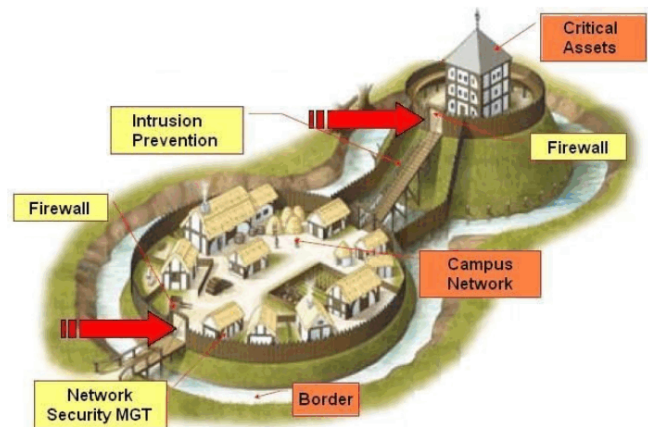
Security implies trust

Defence in Depth

Information Security draws idea from conventional military doctrine

Defense in depth:

- Moat (with moat monsters)
- Drawbridge (with spikes)
- Protective walls, narrow stairs
- Offensive Security: Archers, Soldiers with boiling oil etc.



Moat = A waterbody, Moat Monsters = Animals or stuff that attacks any intruders like sharks, crocodiles, etc.

So Information Security is inspired by conventional military defence systems which were designed around 7 to 8000 years ago.

Information Security

Network Security Gateway (MGT)

Combination of two or more security solutions that prevents unsecured traffic from entering the internal network of an organisation.

Firewall (Network + WAF, Web Application Firewall)

A device that forwards packets between the less secure and more secure parts of the network by applying rules that determine which packets are allowed to pass and which are not.

Intrusion Detection & Prevention System (IDS / IPS)

A security function that examines more complex traffic patterns against attack signatures/patterns and alerts administrators about an attack on the network and can prevent the initial packet from entering the network (function of IPS).

Honeypots

A system designed to look like something that an intruder can hack. Normally built for many purposes but the overarching purpose is to deceive attackers and learn their tools and methods.

Hardened Systems (secured with Antivirus and Antimalware)

Network devices and end-points in an organisation which carries critical information and generally equipped with host-based security isolations.

Authentication

Authentication is the process of proving you are who you claim to be.

Mechanisms:

Something you know (passwords)

Something you have (tokens/OTPs)

Something you are (biometrics)

Passwords

Consist of a sequence of characters or numbers of both which are used to verify the identity of a user in order to access various resources in a computing system which are generally not accessible without a valid password.

Good passwords are the first line of defense against malicious attackers.

What makes a good password?

Atleast 10 characters long

Should not contain user name, real name, institution name

It should not contain any complete word or dictionary word

It should contain characters from each of the following categories:

- Uppercase letters

- Lowercase letters

- Special characters

- Numbers

How do passwords work?

Creation

- Users enter a password for the first time (plain text).
- System forces the password to comply with complexity rules.
- Ideally passwords should be transmitted to the system over encrypted channels.

Storage

- User entered password is hashed and stored at the system database.
- Hashes are one-way hash functions, i.e. encryption is easy but decryption is next to impossible.
- Algorithms used, MD5, SHA256, Blowfish, LM, NTLM, Bcrypt, Scrypt, PBKDF2

Comparison

- User enters a password to authenticate. System takes the password and hashes it.
- It then compares the hash of what the user entered against the hash stored in the password file.
- If they match, allow access. Otherwise decline.

Authorization

Mechanism of verifying that a particular user is allowed to perform an action that they are attempting.

Does subject S have the right R for object O?

Subject: Various Users

Rights: Read, Write, Execute

Objects: Files, programs, etc.

In the real world, this is often implemented as Role Based Access Control (RBAC).

Various roles are defined, users are assigned to those roles and rights are granted accordingly.

29/01/22

Access Control Methods

Based on Functionality

Preventive: Avoid problems before they occur

Detective: Detect the problem that has occurred

Corrective: Correct the problem that has occurred

Deterrent: Discourages someone from doing an act

Recovery: Restore a resource from an event that has occurred

Compensative: Provides alternative controls to other controls

Access Control Model

ACMs are used for defining the access control mechanism and policy definition for any access to be defined.

That is, ACM defines the way in which a subject will access an object. Model must be chosen such that it fulfills the directives of the security policy.

DAC Model (Discretionary Access Control)

- Access to resources is decided by data owners.
- Access control depends on the owner's discretion and authorization granted to the users.
- For enforcing the security policy, Access Control Lists (ACLs) are used.

MAC Model (Mandatory Access Control)

- System's security policy is enforced by the operating system with the use of security labels.
- Resources have security labels that contain data classifications and the users have security clearances.
- When information classification and confidentiality is important, this model is used.
- Most restrictive access control model.
- End-user cannot set controls.
- In simpler words, in this model, resources, for example, files have security labels assigned to them such as "Secret", "Super Secret", "Super Duper Secret", etc. and users will be assigned security clearances. Depending on whether a particular user has the required security clearance for performing a particular action on a given file, access will be granted or denied by the operating system itself.

RBAC Model (Role Based Access Control)

- Also known as Non-Discretionary Access Control.
- Access is granted depending on the subject's role and/or designation.
- Permissions are assigned to particular roles in the organization and then users are assigned to roles.
- Following are the four commonly used RBAC architectures,
 - Non-RBAC
 - No Roles are assigned and there is just one master user.
 - Can have potential uses in forex, crypto control rooms where there is just one console and one user that acts as the master.
 - Limited RBAC
 - Hybrid RBAC
 - Full RBAC
- Hybrid and Full RBAC are the typically used RBAC models in a system.

ABAC Model (Attribute Based Access Control)

- **Rules for access:** Define rules for access which decide how a subject can access the object.
- **Constrained User Interface:** Constrain user interfaces which restricts users' access to a system or application. Constraining is done by disabling certain views or information or functions.
- **Access Control Matrix:** It has subjects and objects in a table and indicates the actions a specific subject can take on an object. This matrix can be dynamic and change depending on the same, so for example, in the morning, the subject is a cashier and in the afternoon, the subject is a data entry operator, etc.
- **Content:** Based on the content within an object the access can be granted.
- **Context:** Decisions are made by "reviewing the situation".

Authentication Contd.

Authentication Techniques

Two-Factor Authentication (2FA)

- Despite all the passwords there are many services that allow you to add a second level of security, through the use of 2FA.
- It can be either a code generated on your device or sent to your phone.
- At first glance, this type of authentication may seem much more reliable than simple passwords but there are some problems too like the user could lose access to their SIM card or the phone or the process that is responsible for the code generating (like an app).

Captcha Test

- Its main goal is to make sure that you're not a robot. Users are asked to perform some tasks that bots are not capable of doing.

Types of Captcha tests,

3D Super Captcha - Requires identifying an image rendered in 3D

"I'm not a Robot" Captcha - Requires a user to check a box

Marketing Captcha - Requires typing a particular word or phrase related to a sponsor brand

Math Captcha - Requires a user to solve a simple mathematical task

Nowadays with the help of AI/ML especially these captcha puzzles can be solved but it is still time consuming and requires the guidance of a sophisticated hacker. So timeout timers can be placed in order to deter bots that try to solve the puzzle but take longer than the average human.

Biometric Authentication

- Relies on the unique biological characteristics of a person to verify whether their identity is authentic or not.
- A user's biometric data is captured and then stored in the database.
- One of the main advantages of biometric data is that you won't be able to forget or lose it.

Types of Biometric Authentication,

Finger Vein Identification - Most common means of authentication that is used in a majority of digital devices.

Face Identification - Capable of scanning and identifying your face.

[Will also detect "liveness" of the person by detecting blinking of the eyes and movement and stuff like that]

Voice Identification - Relies on specific characteristics created by the shape of the speaker's mouth and throat.

Fingerscanning - Resembles ink-and-paper fingerprinting process. This kind of authentication is also found as a Touch ID.

[Can be faked by using cheap tricks found on Youtube]

Iris Recognition - Identifies people based on unique patterns within the ring-shaped region that surrounds the pupil of the eye.

There's more but these are the most common ones.

Some terms to remember,

False Acceptance - A hacker is able to bypass the authentication mechanism because the mechanism concluded the hacker's credentials were valid even though they were not.

False Rejection - A legitimate user is denied access because the authentication mechanism concludes that the provided credentials are invalid even though they are valid.

The ratio of False Acceptance and False Rejection is called the Equal Error Ratio. This metric essentially measures the accuracy of the Authentication mechanism.

Fingerprint Scanning has an Equal Error Ratio of 3.47% which means that a person has a 3.47% chance of being falsely rejected as well as falsely accepted.

Approx numbers, Face: 2.4%, Finger Vein: 0.9%, DNA < 0.5%

Machine Learning

- Machines are becoming more and more capable of observing and analysing human behaviour.
- In the future, a machine will not only look at biometric data such as fingerprints, voice or face identification but also look at human behaviour.
- For instance, our computer would be capable of recognizing the way we type our messages or passwords or even the way we talk on the phone.
- As a result, by learning the way we behave ourselves, our devices will be able to determine their true owner and in case of danger, it will be able to shut down or erase the data stored on the device.
- This could be a very useful passive intelligence technique for authentication.

Public and Private Keys

- This kind of authentication is the main characteristic of asymmetric cryptography.
- It can be mostly found in systems such as Bitcoin but public and private key-pairs might easily find a use in authentication systems as well.

- The user's private key can be stored on the device and the public one can be uploaded and stored on a service's servers. As a result you'll be able to use the same key-pair for various services.

- A crude analogy of this would be sending a parcel in a suitcase which has a presslock on it, anyone can lock the suitcase by just pressing the presslock and closing the suitcase. But to unlock the suitcase you must know the passcode which is only accessible to you.

The presslock is the public key and the passcode is the private key.

The public key can be used for locking the information but not unlocking it whereas the private key can be used for unlocking the locked information.

That is why this is called Asymmetric Cryptography as different keys are used for locking and unlocking.

Social Engineering - Security Threats

Social Engineering is a combination of social, psychological and information gathering techniques that are used to manipulate people to gain access to information or locations that the hacker is not authorised to access.

Social Engineering Taxonomy

Operator: The social engineer which can be a human or a bot or software like spyware, etc.

Medium: How the social engineering (attack basically) takes place.

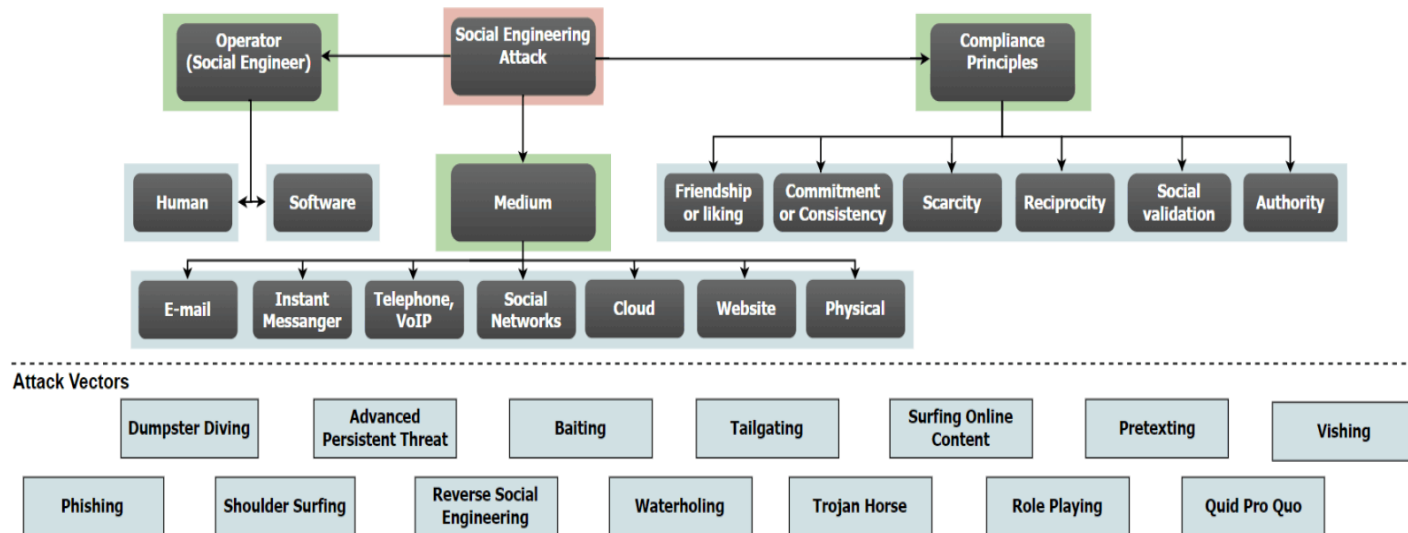
Examples: Email, Instant messenger, Telephone, Social networks, Cloud, Website, Physical.

Compliance Principles: On what principles is the person being socially engineered going to agree to the social engineer's terms.

Examples: Friendship or liking, Commitment or consistency, Scarcity, Reciprocity, Social validation, Authority

Why do these examples make sense?

- Scarcity of Remdesivir during the Covid pandemic caused people to get scammed by people who were selling "Remdesivir".
- A "friend" calls you saying that they need this much money right now or they'll be thrown in jail or something similar to that.
- Similarly you can think of scenarios for the other Compliance Principles listed above.



There's like 300 Attack Vectors possible but sir only put these on here because slide has limited space :P

Social Engineering Attacks

Phishing

Attempt to acquire sensitive information by masquerading as a trustworthy entity via an electronic communication medium, usually an email. Such attacks rely on a mix of technical deceit and social engineering practices.

Spear Phishing

Attackers focus on specific individuals correlating information found on social media and elsewhere to initiate a pointed attack.

For example, the attacker saying that they follow your Instagram videos and are an avid viewer or something similar that requires information specific to you only and gain your trust.

Whaling

Attackers concentrating on high value individuals, generally senior management staff of an organisation following spear phishing techniques to infiltrate and steal valuable organisation data.

Vishing

Attackers directly involve in a digital conversation using voice solicitation techniques and digital messaging techniques to gain access to account information and to penetrate and modify confidential organisation information.

Pretexting

Attackers pretending to be victims and call organisation helpdesks to gather information or penetrate the system by asking the IT helpdesk to click a link to take control of the organisation's system and escalate privileges.

IT helpdesks are there to help any type of user with any type of IT problem so that's why they are typically super users of the system and thus they are a very attractive target for attackers.

SMSishing

Attackers use a text or an image or a web link to gain information about a victim's digital device and steal valuable personal and organisation information.

Sextortion

Widely used form of online blackmail where a cyber scammer threatens to reveal intimate images or videos of someone online, often to their friends, family, work colleagues or social media lists unless they pay a ransom quickly.

[Do note that your phone and laptop cameras can be turned on even when you are not using them and you can be remotely recorded without you ever knowing about it, so just be careful :)]

How to tackle Sextortion?

Don't panic.

Don't communicate further with the criminals.

Change your password to the email id (in case you got the mail from your own email id).

Don't pay.

Preserve evidence that was used by the hacker to communicate.

If it is repeated then give a complaint to the Cyber Crime Cell of Police.

Impersonation

Attacker identifies a way to enter into your facility like a courier delivery executive or tech staff to check internet connectivity, etc. to gather valuable information on the organisation.

Pharming

Attacker redirects victims to a duplicate website, even if the user correctly entered the intended site.

Dumpster Diving

Attackers search the trash of an organisation in order to gather deleted data in a digital environment.

Tailgating

Attackers gain access to secured areas by typically following a person with the required security privileges into an area with access restrictions.

Baiting/Quid Pro Quo

Attackers would make the victim grab a digital device that has pre-installed malware to be used in organisation computers and steal information.

Social Media Security

People accidentally or unknowingly post personally identifiable information or confidential information on the Internet.

This may include employees sharing information specific to their organisations too, for example, an employee posting on social media that they won the “Best Innovation Award for Encryption Design” and describe the entire innovation presented or something specific like that, that makes the employee a valuable target for manipulation or the post can even directly tell the attackers information about the organisation.

Additionally, it is not so easy to delete such information once posted on the internet in most cases.

Juice Jacking

The attacker gains access to phone data via external charging stations (in trains, airports, public places, etc.) with the help of USB ports that are part of the charger.

So the charging port is externally connected to a chip that will store data of all phones that are connected on that port for charging.

How to avoid this?

- Use a data disabled charger.
- Carry your own power bank.
- Disable data transfer option in your phone while charging.
- If possible, switch off your phone.

Application Security

Cross Site Scripting (XSS)

It allows attackers to inject client side script into a web page viewed by others.

It allows attackers to bypass access controls and gain potentially confidential information.

Mitigating XSS

- Do not trust anything coming from the browser, always validate user input.
- Perform client-side as well as server-side validation.
- Escape HTML before inserting into your application.
- Use standard libraries rather than writing your own stuff.
- Use HTML encoding.

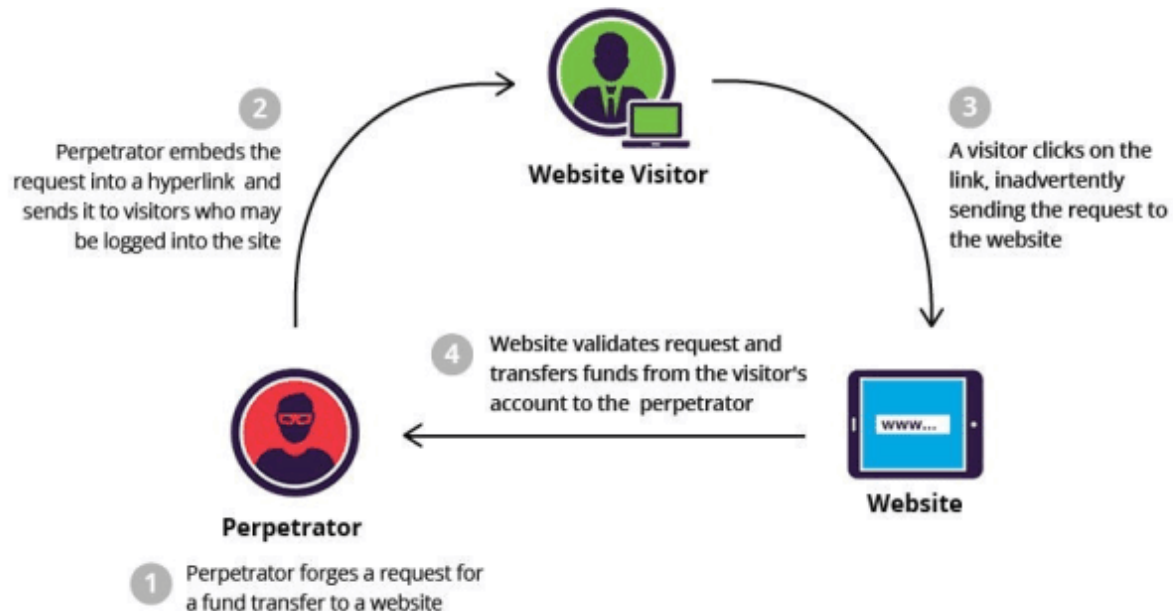
Cross Site Request Forgery (CSRF)

CSRF is an attack wherein a malicious attacker forces an end user to execute unwanted actions on a web application in which they're currently authenticated.

Suppose a website allows users to delete their account via a delete button that points to, ["http://www.website.com/deleteuser.do"](http://www.website.com/deleteuser.do)

CSRF would occur if an attacker asks a logged in user of the website to visit the attacker's page and it has this HTML,

<img src="<http://www.website.com/deleteuser.do>



Prevention of CSRF

Use Referrer header

Use CSRF tokens (which will be used to distinguish between legit and forged requests)

Security Misconfiguration

Three key areas of focus,

1. Unpatched software or software misconfiguration.
2. Improper file/directory permissions.
3. Default accounts with their default passwords.

Directory Traversal

- This is a vulnerability that allows attackers to access restricted directories and execute commands outside of the web server's root directory.
- It can also be exploited to gain shell access to the underlying operating system.
- It can lead to significant leak of confidential information and configuration details.

Default Passwords

Some websites can have default accounts setup with default passwords that can be used to login to the website and gain access to services.

Google Dorks can be a useful resource for finding websites that have potential issues like these.

Google Dorks are posted by ethical hackers or employees of a particular organisation that will post CSRF, XSS attacks, default pages being exposed, etc. for the community to learn from. Ofcourse the community can also include hackers which is sad :(

SQL Injection

- An attack where an attacker can execute malicious SQL statements into an application.
- Using SQL Injection, attackers can bypass an application's authentication & authorization controls and retrieve contents of the entire database.
- In some cases, the attacker can even spawn a shell on the remote DB server leading to complete compromise.

Broken Auth & Session Management

User authentication credentials are protected and stored using hashing or encryption.

Problems arise in this department when,

- Credentials can be guessed or overwritten through weak account management functions (e.g. account creation, change password, recover password, weak session IDs, etc).
- Session IDs could be guessable or exposed in the URL.
- Passwords, session IDs and other credentials are sent over unencrypted connections.
- No checks/controls over brute forcing.

Cryptography

It is the art and science of keeping messages secure.

It is the process of encrypting plain text using a key into cipher text.

Representation:

Encryption: $E_{K1}(M) = C$

Decryption: $D_{K2}(C) = M$

Where, M = Message, C = Ciphertext, K1 = Encryption Key, K2 = Decryption Key,
E() = Encryption Function, D() = Decryption Function

Key Objectives:

Authentication

Integrity

Non-Repudiation

History

Steganography

Hiding text via a variety of mechanisms.

Example, tattoos on a bald head, text embedded in images, etc.

Substitution Cipher

Each plaintext character is replaced by another character.

Example, Caesar Cipher

i) SUMIT (Plaintext)

11111 (Key: Monoalphabetic Substitution)

TVNJU (Encrypted Text)

[All characters are shifted by 1 position]

ii) SUMIT (Plaintext)

12312 (Key: Polyalphabetic Substitution)

TWPJV (Encrypted Text)

[S is shifted by 1, U is shifted by 2, M by 3, ...]

In this case both sender and receiver of the message or data must agree to the key, i.e. the substitution logic.

Transposition Cipher

Plain text characters are not substituted, instead their order is changed.

For this both sender and receiver agree to a predefined grid size that will define the encryption and decryption key.

Plain text: THISCLASSISATIIIT-B

Transposition (on a predefined grid of size 5x4)

T	H	I	S	C
L	A	S	S	I
S	A	T	I	I
I	T	-	B	

Encrypted Text: TLSI HAAT IST- SSIB CII

Functions

One Way Functions

Relatively easy to compute but hard to reverse.

Given x it is easy to calculate $y = f(x)$. However given $f(x)$ it is very hard to calculate x .

$4 * 3 = ?$ But $12 = x * y$ is not very easy to calculate.

Example, breaking a white porcelain plate.

Easy to break but not to put back together.

Trapdoor Functions

They are easy to compute but hard to reverse. However, if a secret is known then you can compute the reverse too.

Example, Easy to take apart a watch but difficult to put it back together. However, having a manual makes the reassembly process easier too.

Solving $12 = x * y$ but you are given the secret that $x = 4$, then you can easily compute that $y=3$.

Hashes

- Produces fixed length output for variable length input.
- Hashing is a one way function: knowing the plain text you can easily create the hash but you will be hard pressed to figure out the plain text from a hash value.
- A good hash function is collision free: meaning there is no other plaintext which when hashed produces the same hash.

Algorithms

Symmetric

Symmetric Key algorithms are those where the same key is used for encryption as well as decryption.

An important requirement and a significant challenge with these algorithms is that the sender and receiver must be able to exchange keys securely.

Further divided into,

Stream: Operate on a single bit at a time

Block: Operate on a block (64 bits) at a time

Asymmetric

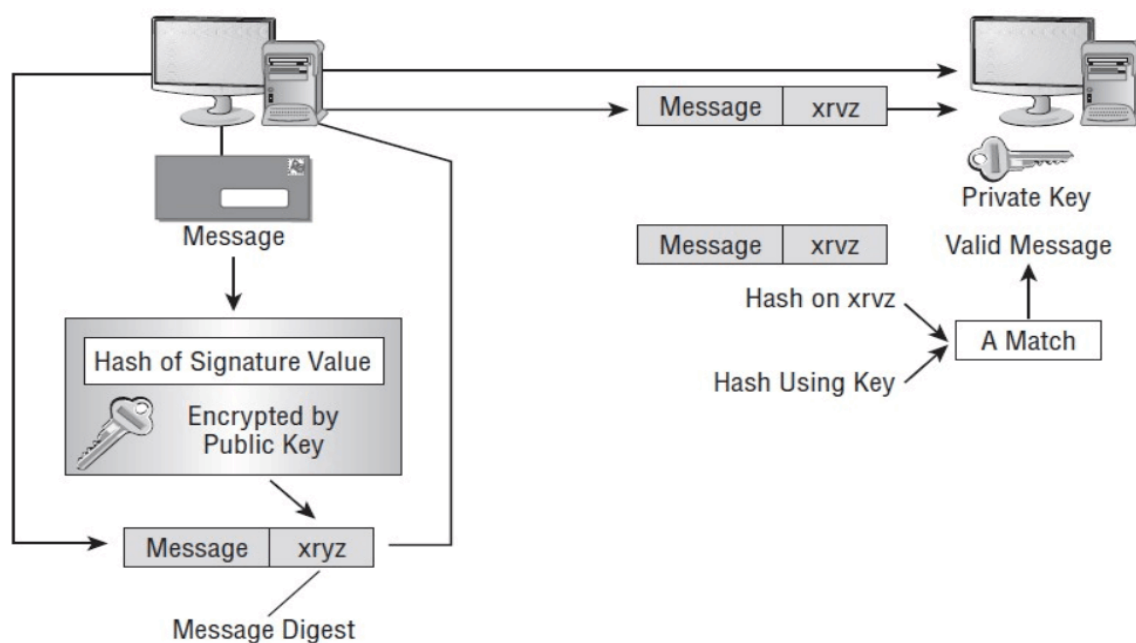
- Those algorithms where the key used to encrypt is different from the one used to decrypt.
- Furthermore, the decryption key cannot be derived from the encryption key.
- There are two keys, public key (known to everyone) and private key (known only to the owner) and these keys are mathematically related.

Comparison

- Public key algorithms are slow.
- Symmetric key algorithms are at least 1000 times faster.
- Symmetric key algorithms have challenges with key exchange.
- **Sometimes a hybrid approach makes the most sense which is why the public key is used to lock and the private key is used to open which is the Asymmetric approach.**

Digital Signatures

- An electronic mechanism to prove that a message was sent from a specific user (provides for non-repudiation) and that the message wasn't changed while in transit (also provides for integrity).
- Digital signatures operate using a hashing algorithm and either a symmetric or asymmetric encryption solution.
- The message is encrypted using the encryption system and a second piece of information, the digital signature is added to the message.
- Most digital signature implementations also use a hash to verify that the message has not been altered, intentionally or accidentally, while in transit.



xryz = Hash of Signature value = Digital Signature in this case

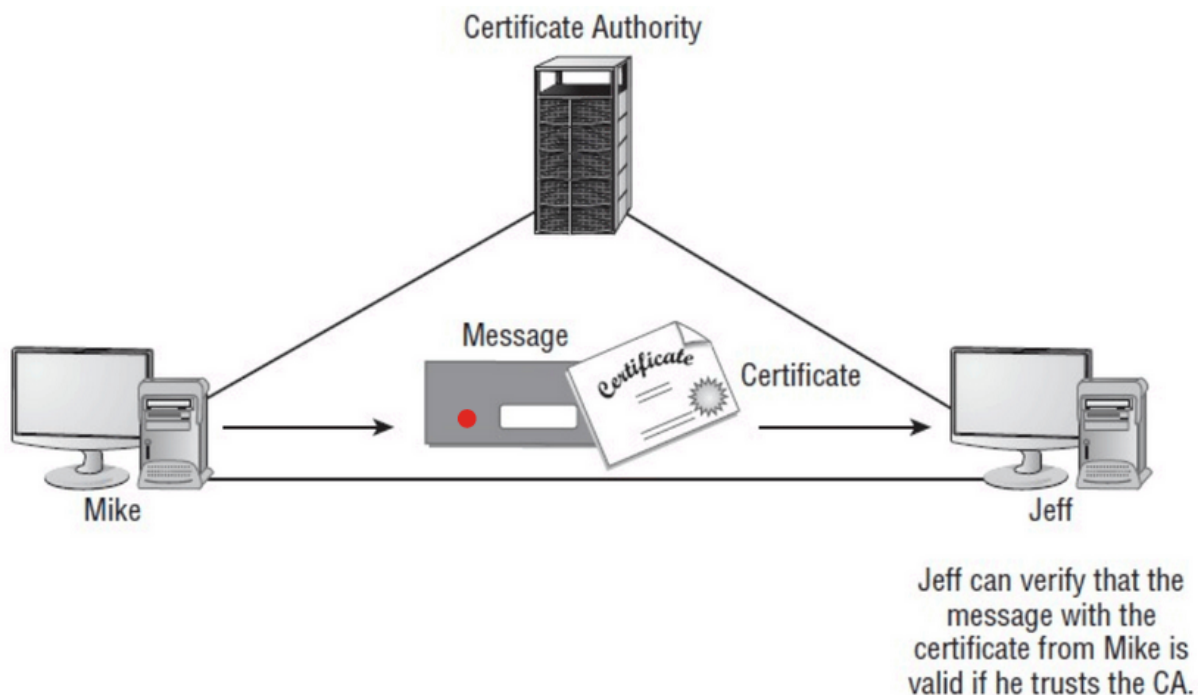
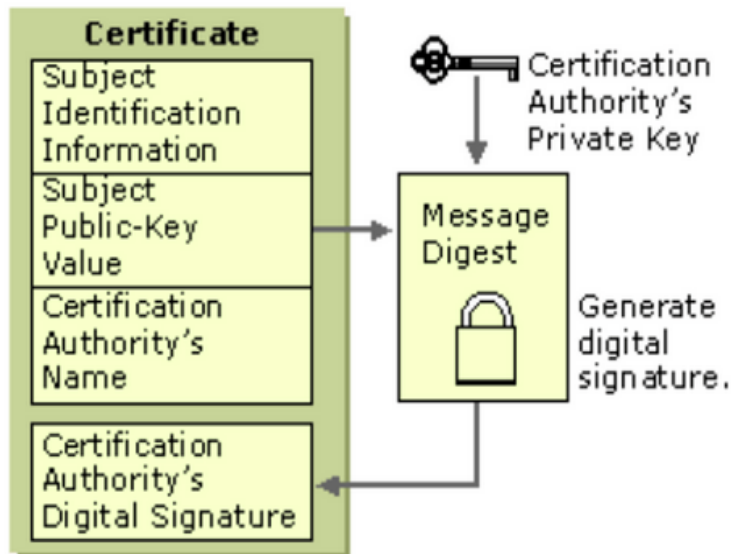
Message + Digital Signature = Message Digest

Receiver uses the private key on the Digital Signature to verify that the signature is a match and so the message attached is also valid and should be decrypted using the private key.

Digital Certificates

- A digital certificate is nothing more than a mechanism that associates a public key with an individual.

- Digital certificates serve a single purpose: proving the identity of a user or the source of an object.
- They don't provide proof as to the reliability or quality of the object or service to which they're attached to, they only provide proof of where that product or service originated.
- Certificates work under a theory known as the trusted party. This theory states that if user A trusts user C and user B trusts user C, then user A can trust B and vice versa.



05/02/22

Cracking vs Hacking

Cracking = Breaking into something, once it's done, the "thing" is broken, so no need to break it again. For example, you lost your house key so you break into your home using any means necessary, so you've basically just cracked into your own home.

Hacking = You are not allowed to enter a particular area/zone but you use illicit means to bypass authentication checks and enter this area/zone.

For example, you get into your home using a duplicate key.

In simple words, getting into a system (where you aren't supposed to enter) without breaking the authentication system is called hacking whereas trying to break the hash function used for encryption using rainbow tables (hash values of most frequently used passwords) or techniques like those to identify the algorithm being used is cracking.

FYI: MD5 (Message Digest 5) & WEP (Wired Equivalent Privacy) [encryption for Wi-Fi] are crackable encryption algorithms.

Passwords should be atleast 10 characters long, must contain uppercase, lowercase, number and special characters.

Passwords of 8 characters can be cracked (brute forced) in under 24 hours.

12/02/22

Network Security

Network Security deals with communication privacy, information confidentiality and integrity over the network, controlled access to restricted network domains and sensitive information, and using public networks for private communications.

Data-in-Motion, Data-at-Rest, Data-in-Transit

When data is moving from one location to another then its data-in-motion.

When data has reached its destination, then its data-at-rest.

When data still hasn't reached its destination but is currently waiting in some queue to be sent out, then its data-in-transit.

How to secure data-in-motion?

VPNs (Virtual Private Networks)

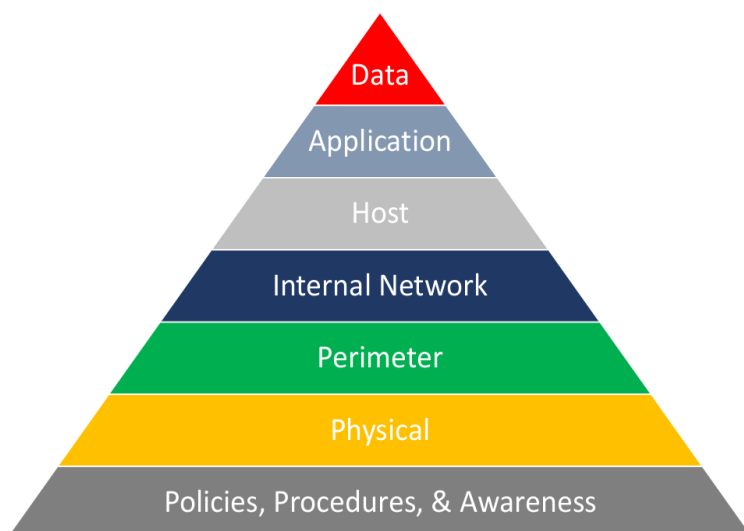
- A virtual private network extends a private network across a public network and enables users to send and receive data across shared or public networks as if their computing devices were directly connected to the private network.
- It establishes a tunnel between two endpoints and allows for end-to-end encrypted communication between them.
- So an external user will be able to see that some communication is happening but no way of knowing what exactly is being communicated.

Types of Threats

Network-based
Host-based
Application-based

Defence in Depth for Cybersecurity

- Defence in depth is the concept of protecting a computer network with a series of defensive mechanisms such that if one mechanism fails, another will already be in place to thwart an attack.
- It involves the use of multiple layers of security to protect the information assets in the organisation.
- This approach strives for security by hardening and monitoring each system, i.e. each system is an island that defends itself.
- Extra measures are still taken on the perimeter systems but the security of the internal network does not rest solely on the perimeter systems.



First layer is the policies and procedures that you have implemented for the system and the general level of awareness the system and the people involved with the system have when it comes to cybersecurity.

Second layer is the physical security where computers come in, i.e. computers on the premise itself and whether they are secure enough from external threats and how much authorization they have over the entire system. For example, someone can sneak their way onto the premises of your business and just plug off the main servers and thus your entire system goes down just like that and none of your cybersecurity was breached either. So securing these servers physically like guards, placing them in a secure location, etc. becomes part of physical security.

Perimeter security refers to the internal perimeter of the system like border gateways and how secure they are (this is referring to digital perimeter, i.e. border between the internal network and outside Internet).

Internal network => Virtual LAN (in more depth later)

Host => End-points of the system which requires end-point security.

End-point security is provided by antivirus.

Application => Security of the virtual ports of the device. An application runs on each port. Port refers to the ports that we mention in TCP and IP protocols.

Secure Shell (SSH), Transport Layer Security (TLS), etc. are all part of application security.

Data => Encryption of data, i.e. cryptography.

Demilitarised Zones (DMZ)

In computer networks, a DMZ, or demilitarised zone, is **a physical or logical subnet that separates a local area network (LAN)** from other untrusted networks -- usually, the public internet. DMZs are also known as perimeter networks or screened subnetworks.

So your system/business's internal network has to be a DMZ.

Web Application Firewall (WAF)

A *WAF* or *web application firewall* helps protect web applications by filtering and monitoring HTTP traffic between a web application and the Internet.

Security Information & Event Management (SIEM)

SIEM stands for **security information and event management** and provides organisations with next-generation detection, analytics and response.

It is an improvement over the firewall but it is not a replacement for it as it provides an additional layer of security.

A firewall provides your first line of perimeter defence. It looks at traffic and creates logs reporting on the traffic that has been allowed through or that which has been blocked. Unlike a firewall, a SIEM doesn't look at traffic; it looks at logs and analyzes that information looking for patterns. It cannot stop an attack by itself. To stop an attack a firewall rule or ACL is needed.

This article should help explain things better,
<https://blog.corserva.com/why-siem-if-already-have-a-firewall>

SIEM works from the Perimeter layer upto the Application layer in Network Security.

Media Access Control (MAC) => They will be present on all layers from Perimeters (routers have MAC), Internal Networks (each device in a network will have MAC) and Host (it is a device so it will have MAC ofc).

Each PCI (Peripheral Component Interconnect/Interface) has 65536 ports and each PCI has a MAC address.

PCI is the interface between the motherboard and all peripheral devices like GPUs, CPUs, Network Interface Cards/Controllers (NICs), USBs, etc.

A network interface controller is a computer hardware component that connects a computer to a computer network.

19/02/22

Physical Security

Physical security is the protection of personnel, hardware, software, networks and data from physical actions and events that could cause serious loss or damage to an enterprise, agency or institution. This also includes protection from fire, flood, natural disasters, burglary, theft, vandalism and terrorism.

Utmost importance is given to protection of personnel/human beings, everything else can be recovered (I doubt data can be recovered but that's besides the point sir is making) but a human cannot be recovered.

It is often overlooked and its importance underestimated, in favour of more technical threats such as hacking, malware and cyber espionage.

However breaches of physical security can be carried out with brute force and little or no technical knowledge on the part of an attacker.

Physical security has three important components,

Access Control

Surveillance

Testing

Physical Security Protection

The physical measures and their associated procedures to safeguard and protect against,

Damage

Loss

Theft

Implementing controls that discourage attackers by convincing them that the cost of attacking is greater than the value received from the attack.

Physical Protection Systems (PPS) Plan

1. Determine PPS Objective

a. Facility Characterization

- Characteristics about the facility to be protected. Is it a bank or a nuclear power plant or something like that?

b. Threat Definition

- Depending on the facility characterization, define what constitutes a threat to the facility and determine the types of threats that can happen to this facility.

c. Target Identification

- Based on the facility and threats defined, identify the targets that attackers can potentially target.

2. Design PPS

a. Detection

- How quickly can you detect that there is an intrusion in the facility.
- Can use exterior sensors, interior sensors, alarm assessment (what kind of alarm is appropriate, blaring sirens, silent alert systems, etc. and where should the alarm signals be sent), alarm communications and display, entry control.

b. Delay

- Once an attacker is detected, you have to delay them from reaching the target and this is why we have Access Delay components.
- This can include trapdoors, rough terrain, obstacles to reach the target building like high walls, fences, thorny bushes, etc.

c. Response

- Response Force (who is going to respond to the threat/attackers)
- Response Force Communications (communication between the defenders that will determine how to respond to the current attacker/s)

3. Analyse PPS Design

This basically tells you how good the design is. The evaluation is usually done by computer models (AI/ML powered) which uses existing standards and architecture principles for the given facility type and threats in question to compare the given PPS against.

Components of analysis,

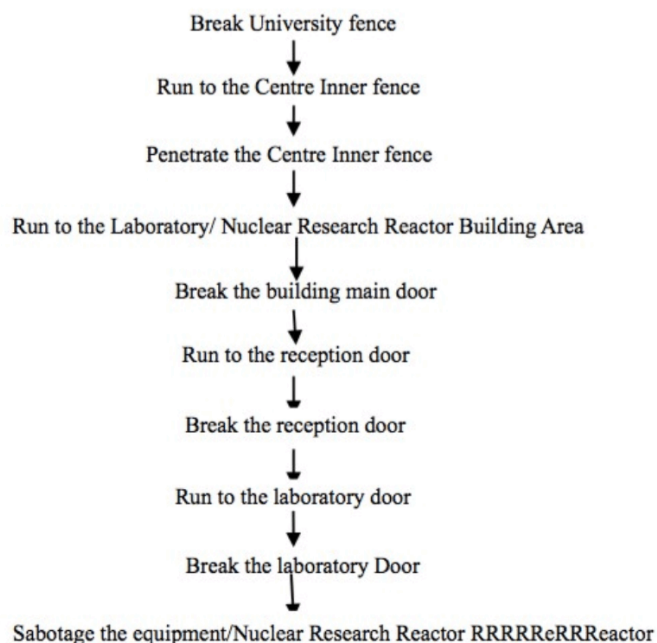
EASI Model (Estimation of Adversary Sequence Interruption)

Adversary Sequence Diagrams

Computer Models (AI/ML based systems)

Risk Assessment

Adversary Sequence Diagram Example for a Nuclear Plant facility that's adjacent to a Nuclear Research university and there's one vulnerability point where university students can enter the plant from the university hostel side via a fingerprint scanner.



Sample EASI Analysis

Table 1. Results of Estimate Adversary Sequence Interruption (EASI) Analysis of the Asset 1

<i>Estimate of Adversary Sequence Interruption</i>	Probability of Guard Communication		Response Force Time (s)	
			Mean	Standard Deviation
	0.95		300	90

Task	Protection Element	P(Detection)	Location	Delays (in Seconds):	
				Mean:	Standard Deviation
1	Break University fence	0.1	B	6	1.8
2	Run to NEC fence	0.2	B	300	90
3	Break NEC fence	0.8	B	6	1.8
4	Run to the building	0.8	B	10	3
5	Break the building door	0.8	B	180	54
6	Run to the reception door	0.8	B	2	0.6
7	Break the reception door	0.8	B	80	24
8	Run to the lab	0.8	B	2	0.6
9	Break the lab door	0.8	B	180	54
10	Sabotage the equipment	0.8	B	30	9
11					
12					

Probability of Interruption:	0.906595291
------------------------------	-------------

PPS Objectives

Describe the threats, vulnerabilities and countermeasures related to physically protecting the enterprise's sensitive information assets.

Identify the risk to facilities, data, media, equipment, support systems and supplies as they relate to physical security.

Goals of Physical Security

Deter
Delay
Detect
Assess
Respond

Layers of Physical Security

<https://www.youtube.com/watch?v=8g0NrHExD3g>

Layer 1 - Perimeter Defence

Fence, CCTVs, Limited entry points with access control.

Anti-Ram Fencing and Gates, Motorised Rolling Gate Operator, Guard Stations.

Layer 2 - Clear Zone - Space between Perimeter and the building's exterior
Intrusion Detection Sensors, CCTVs.

Layer 3 - Facility Facade/Reception Area - Entrance to the building
High Security Key System, CCTVs, Security Vestibule, Card Reader.

Layer 4 - Hallway/Escorted Area/Grey Space
Validates access rights of authorised personnel

Layer 5 - Data Centre Room / White Space
Controlling who gets into here and restricting access of control workers into appropriate spaces is most important.

Layer 6 - Data Centre Cabinet / White Space

Physical Security Part 2

Perimeter/Boundary Security

Perimeter security controls are the first line of defence.

Protective barriers can be either natural or structural.

- Natural protective barriers include terrains that are difficult to cross such as mountains, bodies of water, deserts, etc.
- Structural barriers are devices such as fences, gates, bollards and facility walls.

Landscaping

Shrubs or trees can provide a barrier or an entry point.

Spiny shrubs make it harder for an intruder to cross the barrier.

Adding ponds or similar bodies of water to the perimeter area also makes it difficult for intruders to jump the barrier as they have to now swim through the water.

Fences

Are used to enclose security areas and designate property boundaries.

Should meet specific gauge and fabric specifications.

High-security areas may need a "top guard" (like barbed wire at the top of the fence).

Should meet certain height and location provisions.

They must be checked and repaired on a regular basis.

Fence fabric must be securely attached to poles.

Be sure that vegetation or adjacent structures cannot provide a "bridge" over the fence.

Gates

The portions of a wall or fence system that control and/or egress by people or vehicles and complete the perimeter of the defined area.

[Egress Meaning: the action of going out of or leaving a place.]

Bollards

A rising post designed for use in traffic control and protecting property premises.

Provides security against vehicles ramming into buildings or vehicles stopping near buildings.

Lighted bollards can be used for lighting controls along parks, paths, sidewalks, etc.

This is bollards,



Perimeter Solutions Overview

Geo-Acoustic Sensors

- Cannot be detected, i.e. invisible which makes it appealing.
- Over 300-500 metres detection range.
- Can detect whether tunnelling or digging is going on underground, whether vehicles are approaching, detect footsteps, ultra-lights, UAVs (unmanned aerial vehicles like drones), fixed and rotary wing aircraft, boats, shallow submersibles, etc.
- 360-degree protection.
- This is quite a new technology because it's literally made by Professor Mohanram's team and that fricking insane (dude also has a Masters degree in Geophysics like dude wtf :oooooooooooo).

Microwave Sensors

- Mono-static and bi-static sensors.
- Can be camouflaged as garden lamps.
- Portable tripod sensors for protection of mobile valuables.

Video-Based & PIR Intrusion Detection

- Cheap and alerts guards in the CCTV control room about any detection.
- Ideal for no-man zone violations or buffer zone management.

Fencing Protectors

- Protector of existing walls and barbed/mesh fencing against tampering or scaling (climbing up by another person) with alerts to central control.

Fencing Solutions,

Geo-Acoustic Sensors

SADAR

These two fencing solutions can be integrated with UAVs (drones) for verification of threats and reducing false positives/alerts.

Microwave Fencing -> Comparatively cheaper as compared to the other two options.

- Detectors are intended for the protection of different sites and for detecting an intruder crossing the detection zone.

- Detector operation is based on the creation of an electromagnetic field between Rx and Tx.

This field provides a volumetric detection zone in the form of a long ellipsoid of rotation.

26/02/22 + 05/03/22 = Give up

19/03/22

Gateway Security

L1 Switch is like a light switch, i.e. no configuration inside it, just turns on or off.

L2 Switch is like a fan regular, i.e. on and off + control speed of fan.

L3 Switch has got way more configuration facilities like restricting access, speed, on and off and more.

Firewalls are always L3 switches.

In a corporate environment, the media team is given the most bandwidth because they keep downloading and uploading so much media. For controlling this kind of network configuration we require network devices like switches.

IDS logs malicious IP

IPS blocks malicious IP

A firewall provider has a database of malicious IPs stored on the centralised server of the firewall provider, like how antiviruses do and the physical firewall device that we use checks against this server for each IP to detect whether an IP is malicious or not.

And that's what these Threatmap websites show you. It shows you the attacks detected via firewalls of that company's firewalls like Fortinet, Checkpoint, etc.

Data-in-rest = Stored data that can be anywhere, hard disk, server, pc but is not in access or use.

Data-in-access = Stored data that is currently in access.

Data-in-motion = Data that is in access or use and being transmitted/broadcasted/multicasted.

Data-in transit = Data that is not being accessed or used but is currently waiting to be transferred.

Threats

Automated Threats

Adware = Advertisement Software

These advertisements are a path for something to happen.

We have 65536 virtual ports numbered from 0 to 65535.

The job of these adware is to open a random port for a malicious file to enter into the user's system.

Malvertisement = Malicious Advertisement

Its job is to open a random port and carry malware into the user's system.

Spyware = Spy Software

Its job is specific and its intentions are pre-designed to lookout for a specific file, e.g. file with filenames like accounts, credentials, password, financials, etc.

Spyware is always a self destructible program (once its job is done, it will self-destruct).

To transfer the collected data back to the intruder, one of the technical issues with a system is triggered like buffer overflow (overload RAM by opening multiple copies of a large file). While the RAM is overloaded, the spyware uses SMTP (port 25) if the intruder is outside the network or SNMP (port 161) if the intruder is inside the network to send the file back to the hacker.

Remember that we already counter all such attacks automatically with the help of tools like antivirus and all.

Virus

Virus's intentions are to destroy anything and everything.

Until you detect it and block it.

Trojan

Trojan's intentions are to steal whatever it can and destroy whatever it doesn't want.

It could create a backdoor to make the stealing process easier.

Backdoor = A random port that has been created for sending information to the hacker or even accessing the local system remotely by the hacker.

Worm

Its job is to connect systems for malicious files to travel within a network.

Malware = Malicious Software

The sophistication of all the above or a combination of all the above. In general, a malware is a combination of files like a software or making all the above said malicious files to join together to make a malicious software.

Like Power Rangers, Megazord transformation of all the shitty malicious wares into its final form except Megazords are cool!.

Ransomware

Type of malware which has the ability to encrypt files with RSA 2048 and a combination of AES 128 and multiple other encryption algorithms. By doing this, it will ask for a ransom to release the encrypted file. Ransoms are taken in cryptos.

Ransomware entry is typically via adware and continues to move to other systems in the same networks with the help of a worm and basically it can encrypt all the systems in an entire network within like 30 minutes.

Manual Threats

RAT - Remote Access Terminal

Taking control of a system and making it a bot. An extension of this would be taking control of an entire network and making it a botnet.

Keylogger

This can be automated as well but often it happens that it's a manual attack. Recording keystrokes either in a virtual keyboard or capturing the screen.

Rootkit

One of the most sophisticated manual threats that can sit in the motherboard (in the BIOS), so it is sitting at the lowest level of the machine and can monitor and modify everything basically, the kernel, the registries, the BIOS, etc.

Machine Levels

Motherboard BIOS -> Hard Disk -> Operating System -> Software/Applications -> Data

An antivirus sits on the Applications level, so it can only detect threats in Applications and Data levels but how can it help with rootkits where it sits at the lowest level?

Antiviruses somehow allow you rootkit scans as well. But how?

How do you update BIOS? Via the OS layer, download the new BIOS, trigger the update via the OS which will trigger a restart which has to be approved.

This restart being triggered will replace the old BIOS with the new one.

And this is what a rootkit scan does too, it will restart the PC and scan the entire BIOS to remove it. Sometimes even this doesn't work, in that case you would have to flash the motherboard, clear the BIOS, not even updating the BIOS would work because the rootkit would never allow the update to proceed with.

Flashing BIOS doesn't need hard disk formats but if the rootkit has a backup on the hard disk as well then we're doomed. That's also a small contributor to why this can be so, so dangerous.

Levels of threats

1. Network (where our syllabus is)
2. Host
3. Application

Monitoring

SOC = Security Operation Centre

NSOC = Network SOC

Monitoring is usually done at the firewall or filtering router, so that all traffic coming into the network can be analysed.

Network monitoring involves collecting statistics on usage to determine things and not monitor the data itself.

SIEM is a combination of SEM (Security Event Manager) and SIM (Security Information Manager).

SIEM provides real-time analysis of security alerts generated by network hardware and applications.

SIEM solutions come as software, appliances or managed services.

SOAR - Security Orchestration Automation & Response

This is a more advanced framework than SIEM and it actually includes SIEM as part of its functionalities.

All of these are Operation Softwares which are implemented by various vendors like how antiviruses are implemented by various vendors. It is a methodology/framework that is made by vendors.

25/03/22

Add the architecture diagram later here

[Cloud -> Perimeter thingy]

Routers are not a replacement for Gateway firewalls because of DDoS risks and just because next-gen firewalls are better.

DMZ = Demilitarised Zone
HP = Honey Pot, SB = Sand Box

Secondary FW = From a different vendor to handle situations where the primary firewall fails.
This is used with Port-Forwarding

These firewalls do packet-filtering (along with Antivirus and stuff but App Sec does additional stuff).

App Sec FW = For dev networks
Additional task of Port Services Monitoring

VLANs help reroute traffic as per network requirement, kind of like a role-based authentication situation.

PAM = Privilege Access Management

Monitoring of IP Addresses + Logs only no data

DNA = Distributed Network Attack
10,000 or so attackers (check this again), 15-20 handlers to attack a single machine.

DDoS attack is this only but that's not all, the system being down due to DDoS helps attackers to perform any one of the common attacks like SQL Injection, XSS, CSRF, Broken Auth, etc.

This is where a monitoring system helps.

VLANs can be exposed to outside the network with the help of VPNs (site-to-site VPN).

Read up on the 2020 Cognizant hack.

Passwords can be hacked but hashes remain unique for a given file, so to ensure authenticity have the sender compare the hash value after sending the file with the hash value before sending the file.

SIEM

Add features of SIEM
Copypaste slide content

2016 September Hitachi Payment system attack

Backups

HOT (live) & COLD (not being accessed) Backups

Incremental & Differential backups

Incremental = Modify existing files in new backup

Differential = New copy of the files that have been modified

15/04/22

Introduction to Digital Forensics

Just keep copy pasting slide content before Case Study 1

Types of Cybercrimes:

Insider Attacks

These involve a breach of trust from employees within an organisation.

External Attacks

These involve hackers hired by either an internal or external entity to cause harm to an individual, group of individuals or an entire organisation's reputation.

1. Theft of Intellectual Property
2. Damage of Enterprise IT Systems & Networks
3. Financial Frauds
4. System Takeovers by Hackers
5. Distribution & Execution of Malware

Challenges Presented by Cybercrimes

- Quick and inexpensive exchange of information due to the advancement in Internet and PC technology.
- Easily available hacking tools in the market.
- Use of identity hiding techniques by attackers; makes it much more difficult to get hold of them.
- Use of anti-forensic techniques to conceal the attacker's identity.
- No actual presence of eye witnesses, fingerprints & DNA.

Need for Digital Forensics

Forensics is the process of using scientific knowledge for collecting, analysing and presenting evidence to the courts.

Forensics deals primarily with the recovery and analysis of latent evidence.

The evidence has to be examined and processed in a consistent scientific manner to ensure that evidence is not accidentally altered and that appropriate conclusions are derived from that evidence.

When you connect drives containing evidence to a PC for forensics analysis, log entries will be generated which is essentially tampering of evidence.

You avoid this by attaching the drive to a Write Blocker which is then attached to the USB port.

Also note that you first clone the drive and then you work on the cloned data so you don't end up tampering the original again.

Cloning is done via the **Bit-by-Bit copying method**, which is very thorough (even copies the data related to the addresses of the data blocks) and inefficient and takes about 8 hours to copy a 500GB drive whereas normally it'll take like 10-20 minutes on a SSD.

Add info from Case Study 1 slide onwards

16/04/22

Phases of Hacking

Enumeration - Processing the output of the Scanning phase and listing everything down and analysing how this can be used for exploiting vulnerabilities.

Maintaining Access - Opening a backdoor, i.e. a port.

Check out Google Dorks, each query is most likely tied to a vulnerability, like, *inurl php id=1*
Check out *Google Hackers* research paper that shows how to use the search engine for a lot of cool haxx stuff.

Metasploit => Most popular pen-testing software

[exploit-db](https://exploit-db.com/) for finding out exploits, ensure that applications that you make don't fall in these exploits.

cve.mitre.org - Common Vulnerability Exploits

The mission of the CVE® Program is to identify, define, and catalog publicly disclosed cybersecurity vulnerabilities.

attack.mitre.org

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the

development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

cwe.mitre.org - Common Weakness Enumeration

CWE™ is a community-developed list of software and hardware weakness types. It serves as a common language, a measuring stick for security tools, and as a baseline for weakness identification, mitigation, and prevention efforts.

<https://nvd.nist.gov/> - National Vulnerability Database

The NVD is the U.S. government repository of standards based vulnerability management data represented using the Security Content Automation Protocol (SCAP). This data enables automation of vulnerability management, security measurement, and compliance. The NVD includes databases of security checklist references, security-related software flaws, misconfigurations, product names, and impact metrics.

22/04/22

ping -t google.com = Ping to death

tracert google.com = Trace route to specified URL, i.e. the router addresses in between

nslookup = Namespace lookup, IP address and details of namespace.

netsh = Open Network shell

wlan show profiles = Check profiles of all WLANs that you have been connected with

wlan show profiles name="Name of some WLAN" key="clear"

wlan show profiles name="Name of same WLAN" = You can see the WiFi Password of this WLAN

Do not connect to any WiFi and use the allow for public networks option.

netstat = All connections that you are connected with.

* symbol in tracert output = ICMP packet disabled, typically done to reduce output packet bandwidth as such specialised routers are intended for just passing on the required packets forward.

netstat -ab = Check all outgoing connections on your PC with port + IP address + all that good stuff

These commands are helpful if the hacker tries to spoof your IP address and attack you using your own IP address.

Install nmap, perform intense scans for a given website or IP address.

This will give you a lot of info. Find the open ports and then look up exploit-db, CVE, etc. to find vulnerabilities related to the open ports and its haxx time.

Two types of VPNs exist,

IPSec => VPN at the IP level, all traffic will go through VPN

SSL Sec => VPN at the browser level, your web browser traffic will go through VPN

So you can actually have SSL Sec VPN on top of IPSec VPN for DOUBLE BAM VPN.

Wireshark can be used at your gateway to monitor and analyse web traffic.

23/04/22

UTM = Unified Threat Management, Next-Gen Firewall

UEBA = User Experience Behaviour Analytics

IPS = Antivirus, Intrusion Protection System

Probability of IPS & IDS blocking a threat that is legit = 3/10

VDI = Virtual Desktop Image

You configure the PC at the BIOS level to connect to an Internet connection with the cloud. This cloud connection enables you to connect with a server that gives you compute, storage and network access. The PC literally has nothing in it, not even the OS but still it works.

NMap is not accepted as a vulnerability assessment tool. This is why we rely on WireShark for monitoring, but for other departments even Wireshark is not accepted.

Class A: 10.0.0.0 — 10.255.255.255

Class B: 172.16.0.0 — 172.31.255.255

Class C: 192.168.0.0 — 192.168.255.255

These are the private IP ranges in each class.